

Cardholder Data Encryption

Purpose

The purpose of these guidelines is to recommend best practices for protecting Botium Toys' cardholder data, reducing the risk of financial and reputational damage to the organization.

Scope

These guidelines apply to IT and any personnel responsible for managing or overseeing systems that process, store, or transmit cardholder data.

Safeguards

- Use encryption, digital signatures, and cryptographic hashes to protect the confidentiality and integrity of stored data in files, databases, and other resources.
- Use full disk encryption to protect data stored on user endpoints.
- Restrict the use of removable media such as external hard drives and flash drives to prevent data exfiltration.

Policy Sanctions

Failure to implement these safeguards exposes Botium Toys to noncompliance with PCI DSS Requirements 3 and 4, which may result in regulatory penalties, increased transaction fees, loss of card processing privileges, and reputational and financial harm to the organization. Individual violations of these guidelines such as unauthorized handling or removal of cardholder data will be addressed through disciplinary action consistent with Botium Toys' human resources procedures, up to and including termination.